TD 8 : Identifier les menaces et mettre en œuvre les défenses appropriées

Vous venez d'être recruté en tant que stagiaire dans le service informatique et cybersécurité de l'hôpital Saint-joseph à paris (15e).

Le DSI, M. Naouche est très inquiet de toutes les attaques depuis 2020 concernant notamment les hôpitaux et les données de santé.

Il vous demande de lui réaliser une étude des risques et des propositions de solutions pour davantage sécuriser le SI de l'hôpital.

Vous utiliserez les méthodes et outils de la veille informationnelle pour réaliser ce travail.

1. Recensez et décrivez de façon détaillée cinq attaques concernant les hôpitaux (sauf l'Hôpital de Corbeil Essonne).

L'hôpital universitaire de Düsseldorf en Allemagne a été victime d'une attaque dans la nuit du mercredi 9 septembre 2020

Une attaque par ransomware avait bloqué tous les systèmes informatiques de l'hôpital. Les pirates ont trouvé et utilisé une vulnérabilité dans un logiciel de gestion des serveurs pour crypter les données et demander une rançon.

Le ransomware utilisé par les pirate été le ransomware "WannaCry" qui est un ransomware qui bloque les systèmes avec un chronomètre dessus et une adresse Bitcoin à laquelle il faut transférer l'argent.

30 serveurs de l'hôpital ont été chiffrés et un message de demande de rançon avait été laissé sur l'un des serveurs.

Cette attaque a causé la mort d'une patiente car son traitement a été retardé.
L'hôpital a dû rediriger les patients en urgence dans un autre hôpital. L'attaque a également causé des perturbations majeures dans les soins et les opérations administratives.

La cause de cette attaque est qu' une vulnérabilité n'a pas été corrigée dans un logiciel.

Les conséquences de cette attaque sont que les hackers avaient accès aux données médicales et administratives de l'hôpital. Et donc ils ont divulgué les dossiers des patients sur le Dark Web.

Attaque contre le centre hospitalier de Versailles en France le … février 2021

Le centre hospitalier de Versailles a été touché par une attaque par ransomware qui a crypté les données et perturbé les systèmes informatiques. Les pirates ont demandé une rançon pour restaurer l'accès aux données cryptées.

Les impacts ont été la perturbation des services de soins, l'annulation de rendez-vous et le recours à des procédures manuelles. L'hôpital a refusé de payer la rançon et a dû reconstruire ses systèmes.

Cause principale : Infection via un email de phishing ou une faille dans un logiciel.

Leçon à retenir : Mettre en place des sauvegardes régulières et sécurisées pour permettre une récupération rapide en cas d'attaque.

Attaque du CHU de Rouen en 2019 :
En novembre 2019, le CHU de Rouen a été victime d'une cyberattaque par ransomware. L'attaque a paralysé une grande partie du système informatique de l'hôpital, rendant les dossiers des patients inaccessibles et forçant l'établissement à retourner aux méthodes manuels (papier et stylo). Il a fallu plusieurs jours pour rétablir le fonctionnement complet. Aucune rançon n'a été payée, mais les opérations ont été retardées, ce qui a perturbé les soins.

Attaque de Dax (2021) :
En février 2021, l'hôpital de Dax a subi une cyberattaque par ransomware. Les pirates ont crypté les données, exigeant une rançon pour les déchiffrer. Cette attaque a gravement affecté le fonctionnement de l'hôpital, notamment en perturbant les services d'urgence, et a contraint les équipes médicales à travailler sans informatique pendant plusieurs jours, ce qui a également entraîné le report de certaines interventions chirurgicales.

2. Rappelez les règles en matière de conservation et de sécurisation des données de santé pour les organismes qui les gèrent.

Respect du RGPD et des législations spécifiques nationales.

Chiffrement des données et accès réservé au personnel autorisé.

Conservation des données pour des périodes définies.

authentification forte, protection contre les intrusions, sauvegardes régulières, audits.

3. Rappelez les droits des patients sur leurs données.

- Droit d'accès aux données personnelles et médicales.
- Droit à la rectification des données en cas d'erreurs.
- Droit à l'effacement dans certains cas, et possibilité de limiter ou s'opposer à l'utilisation des données.
- Portabilité des données vers un autre praticien ou établissement.

https://www.droits-cabinetmedical.fr/les-droits-des-patients-en-matiere-de-traitement-des-donnees-de-sante-acces-rectification-et-suppression-des-donnees/

4. Indiquez d'où peuvent provenir les failles de sécurité qui ont été utilisées par les attaquants.

- Erreurs humaines : mauvaise gestion des mots de passe, manque de formation à la cybersécurité.

- Systèmes non mis à jour : exploitation des vulnérabilités dans les logiciels.

- Phishing : hameçonnage par e-mails frauduleux.

- Dispositifs IoT non sécurisés : objets médicaux connectés vulnérables.

- Absence de segmentation des réseaux : propagation facilitée des attaques.

5. Proposez des pistes de solution pour sécuriser ces données. Indiquez à M. Naouche comment éviter ce qui est arrivé aux autres hôpitaux.

- Mise à jour régulière des systèmes et applications.
- Chiffrement des données au repos et en transit.
- Formation du personnel pour reconnaître les cyberattaques.
- Authentification multi-facteurs (MFA) pour sécuriser l'accès aux systèmes.
- Tests de pénétration réguliers pour détecter et corriger les failles.
- Sauvegardes fréquentes dans des environnements sécurisés.

6. On a découvert il y a quelque temps que des laboratoires se sont fait pirater les données de 500 000 personnes. Relatez ce qui s'est passé. Comment l'a-t-on découvert ? Que risquent les patients ? Que risquent les entreprises qui conservaient ces données ?

En 2021, une fuite de données a eu lieu en France. Les informations divulguées provenaient d'une trentaine de laboratoires d'analyses médicales situés principalement dans le nord-ouest du pays. Ces données concernaient des prélèvements effectués entre 2015 et octobre 2020.

Découverte de la fuite : La fuite a été révélée par le blog de cybersécurité **Zataz**, qui a mis en lumière l'existence d'un fichier contenant les données de 500 000 patients français. Ce fichier circulait dans des groupes Telegram spécialisés dans la revente de données volées.

Risques pour les patients : Suite à cette fuite, les patients sont exposés à plusieurs risques, notamment :

- **Usurpation d'identité**.
- **Phishing ciblé**, utilisant les informations divulguées pour mener des attaques.
- **Atteinte à la vie privée**, notamment par la divulgation de leurs informations de santé, ce qui pourrait leur nuire dans leurs relations avec des assurances ou au travail.

Risques pour les entreprises qui conservaient ces données :

- **Sanctions financières** : Ces entreprises risquent des amendes infligées par la CNIL.
- **Poursuites judiciaires** : Les patients peuvent intenter des actions en justice pour obtenir réparation des préjudices subis.
- **Atteinte à la réputation** : Cette fuite pourrait entraîner une perte de confiance des patients, nuisant à l'image de l'entreprise.

Affaire de la fuite de données de santé de laboratoires français — Wikipédia
Ce que l'on sait sur l'énorme fuite de 500 000 dossiers médicaux français
Quels risques représente la fuite des données médicales de près de 500.000

7. M. Naouche a entendu parler d'une polémique sur le Health Data Hub. Il vous demande de lui expliquer précisément de quoi il s'agit après avoir expliqué ce qu'est le Heath Data Hub, quelle est sa date de création et par qui a-t-il été créé?

Le Health Data Hub est une plateforme française qui est destinée à centraliser les données de santé pour les mettre à disposition pour la recherche médicale et l'innovation. L'objectif est de faciliter l'analyse et le traitement des données à grande échelle pour des projets de santé publique.

- Il a été créé en 2019 à l'initiative du gouvernement français, sous la supervision du Ministère des Solidarités et de la Santé.

- La polémique a éclaté lorsque l'hébergement de cette plateforme a été confié à Microsoft, une entreprise américaine. Cette décision a montré des préoccupations concernant la protection des données sensibles des citoyens français.

  En effet, certains craignaient que les données soient soumises à des lois américaines telles que le Cloud Act, qui permet au gouvernement des États-Unis d'accéder aux données hébergées par des entreprises américaines, même si elles se trouvent à l'étranger.